NS-004 FINAL INVESTIGATION REPORT

Northstar Services | Fictional training case

Briefing video link	**https://drive.google.com/file/d/119Uu9ll7CrpyE_YUTrCljEyb8Qf7MKEL/view?usp=drivesdk**
Analyst	Umar Mohammed
Report date/version	1 November 2026 / v1.0
Tools actually used	Text editor, spreadsheet (CSV import), SHA-256 utility (sha256sum / Get-FileHash) — confirm these match your actual work before submission.
Scope and authorisation	Fictional case NS-004. Authorised to examine supplied training copies only (08:50–09:45 UTC, 26 October 2026). Junior analyst role: document findings and recommend actions; do not execute containment or account changes.

1. Executive summary

NS-004 concerns a successful credential-phishing attack against maya@northstar.example on 26 October 2026. At 09:00 UTC, a spoofed helpdesk email (E01) using the lookalike domain billing-check.example was delivered. The HTML attachment was saved to NS-LT-12 (P01). Shortly afterward, an external actor authenticated to Maya's account from 198.51.100.44, creating session S-404 (I03). The session successfully read billing-register.csv twice (C01, C03) and was denied access to payroll.csv (C02). The unauthorized session remained usable after a user-initiated password change (I04), then was revoked at 09:40 UTC (I05); a subsequent read was denied (C04).

Severity: High, based on confirmed unauthorized access to sensitive billing data. Immediate priorities are to preserve and examine NS-LT-12, review OAuth grants and active sessions, establish the scope of billing-data access, and determine whether any additional persistence or data transfer occurred.

2. Evidence register and preservation

Source	Record IDs	Collector	Collection time	Limitations	SHA-256 verification	Working copy / transfer
email-evidence.txt	E01–E02	Training lab pack	[Simulated/ Not applicable]	Excerpt; attachment bytes unavailable	[VERIFY AGAINST MANIFEST; DO NOT ASSUME MATCH]	Workbook copy; original ZIP retained intact
endpoint.csv	P01–P04	Training lab pack	[Simulated/ Not applicable]	Excerpt, not full disk image	[VERIFY AGAINST MANIFEST; DO NOT ASSUME MATCH]	Workbook copy; original ZIP retained intact

identity.csv	I01–I05	Training lab pack	[Simulated/ Not applicable]	Excerpt; no full token history	[VERIFY AGAINST MANIFEST; DO NOT ASSUME MATCH]	Workbook copy; original ZIP retained intact
network.csv	N01–N03	Training lab pack	[Simulated/ Not applicable]	Flow records only; no PCAP/decryption	[VERIFY AGAINST MANIFEST; DO NOT ASSUME MATCH]	Workbook copy; original ZIP retained intact
application-audit.csv	C01–C04	Training lab pack	[Simulated/ Not applicable]	Audit excerpt	[VERIFY AGAINST MANIFEST; DO NOT ASSUME MATCH]	Workbook copy; original ZIP retained intact

Handling note: These are supplied training copies, not original forensic acquisitions. A hash match demonstrates byte consistency against the referenced manifest, not source authenticity. Record actual collection times and verification results; do not claim verification unless it was performed. Preserve originals unchanged. Coordinate preservation of volatile evidence before reboot or isolation where operationally feasible.

3. Email and endpoint baseline analysis

E02 is the legitimate control message from helpdesk@northstar.example: it directs the user to a bookmark and says never to send passwords. E01 is consistent with a phishing lure. SPF/DKIM/DMARC passing for billing-check.example would authenticate that sender domain's own mail configuration, not prove the message was sent by Northstar. The display name imitates "Northstar Helpdesk," while the actual host is portal.northstar.example.billing-check.example. The attachment name billing-update.pdf.html indicates an HTML file with a misleading PDF-like name.

P04 is described as a benign baseline event associated with approved change CHG-404 on NS-LT-14. P03 is an alert for invoiceviewer.exe on NS-LT-12 without a corresponding approved change in the supplied evidence. It requires validation, but the process name or alert alone does not establish malware execution.

4. Timeline and correlation

The endpoint clock on NS-LT-12 was reported to be exactly 120 seconds fast; therefore, endpoint timestamps P01–P03 are corrected by subtracting 120 seconds. Other timestamps are left unchanged. WAT is UTC+1. See timeline.csv for the full normalized event table.

Key sequence: E01 delivered at 09:00 UTC; endpoint attachment save corrected to 09:02; network activity to the lure infrastructure at approximately 09:02:55–09:03; failed authentication from 198.51.100.44 at 09:06; successful authentication and S-404 creation at 09:07; billing-register read at 09:08; password change at 09:20; another successful billing-register read through S-404 at 09:25; session revocation at 09:40; read denied at 09:41.

Cross-source correlation connects the successful external authentication (I03), session identifier S-404, and application audit events (C01–C04). This supports unauthorized account/session use and sensitive data access. The available records do not establish exactly how credentials were captured.

5. Findings and impact

- Confirmed unauthorized access: S-404 read billing-register.csv successfully at 09:08 UTC (C01) and 09:25 UTC (C03), with 40,960 bytes returned each time according to the supplied scenario records.
- Access control outcome: payroll.csv access was denied (C02). A later billing-register read was denied after session revocation (C04).
- Session persistence after password change: S-404 remained usable after Maya changed her password at 09:20 UTC. In this scenario, password changes did not automatically revoke existing sessions; explicit session revocation was necessary.
- Limits and uncertainty: N02 is an undecrypted TLS flow, so the evidence does not show a password being transmitted. P03 is an unvalidated alert, not proof of malware. Attribution, complete access scope, and exfiltration beyond the recorded application reads remain unproven.

6. Containment, escalation, and action plan

The session revocation is recorded as executed in the training evidence. As a junior analyst, do not execute account changes or isolate systems independently; obtain the incident lead's approval and use authorised execution owners. See action-plan.csv for owners, priorities, status, validation, and review timing.

Escalate immediately to the incident lead: successful sensitive-data access is confirmed, while endpoint execution, OAuth grants, full network activity, and the complete scope of access remain unresolved.

7. Recovery and monitoring

B01 (immutable backup dated 25 October) is the stronger candidate if restoration later becomes necessary because it predates the incident, is integrity-verified, and passed a restore test in the supplied scenario. B02 is online, post-incident, and unverified. Restoration is not currently indicated by the evidence: the confirmed impact is confidentiality (unauthorised reading), not demonstrated data integrity loss or ransomware. Reassess if integrity compromise is found.

C04 alone is not sufficient for incident closure. It indicates a denied request after revocation, but does not establish that the endpoint is clean, all OAuth grants or tokens are revoked, no other sessions exist, or no further data transfer occurred.

8. Open questions and handover

Missing evidence	Owner	Priority	How it may change the conclusion
Endpoint forensic image / collection (D03)	endpoint_admin	P1	May confirm or refute execution and persistence associated with P03.
OAuth grant and active-session export (D02)	identity_admin	P1	May identify other sessions or grants

			independent of S-404.
User interview	Analyst	P1	May clarify whether Maya opened the attachment, followed the link, entered credentials, or approved an MFA prompt.
Full network and proxy logs	network_admin	P2	May clarify destinations, duration, and possible transfer volumes.
Expanded application audit logs	application_owner / identity_admin	P1	May establish the full scope of billing-data access and affected records.

Handover: D03 and the other listed evidence requests remain pending unless updated with verified results. The incident lead owns the next review. The recorded briefing should cover scope, strongest evidence (successful use of S-404 after password change), uncertainty (malware and exfiltration), and next actions.

9. Analyst conclusion

The supplied evidence supports a High-severity credential-phishing incident involving unauthorized use of Maya's account and successful reads of sensitive billing data. The post-password-change access is the clearest indication that the existing session remained valid until explicitly revoked. The investigation is not ready for full closure because endpoint forensics, OAuth/session review, and broader access/network scoping remain outstanding.

Prepared as a training exercise for fictional case NS-004. No real organisation, person, or system is involved.

Briefing Video

Viewing link: Watch the NS-004 Investigation Briefing